המסלול האקדמי המכללה למינהל
מדעי המחשב

ת.ז הסטודנט:_____
מס' חדר:_____ מס' נבחן:_____

בחינה בקורס: מבוא לאבטחת סייבר
קוד קורס: 689156
תאריך הבחינה: 07/07/2023 שעת הבחינה: 09:00
שנה"ל: תשפ"ג סמסטר: ב' מועד: א'
מרצה: ד"ר מנחם ליבוביץ
משך הבחינה: 01:30 שעות

הוראות לנבחן:
- מספר השאלות בשאלון: 10
- יש להשיב על כל השאלות
- משקל כל שאלה: 10 נקודות
- הבחינה ללא חומר עזר
- שימוש במחשבון כיס/פיננסי: לא
- מחברת טיוטה: לא
- אין לסמן על דף הקידוד ו/או שאלון הבחינה במַדְגֵּשׁ (מַרְקָר) זוהר
- יש לסמן את התשובה הנכונה ביותר בדף הקידוד **בעט שחור/כחול בלבד, באופן ברור ומודגש**
- **רק דף הקידוד ייבדק**
- יש להחזיר את שאלון הבחינה, כולל נספחים (אם קיימים)
- בבחינה זו מתקיים נוהל הוצאת פתקים בשעות: 09:30, 10:00 לזכאי תוספת זמן גם בשעה 10:30

***** חשוב מאוד:**
בדף הקידוד יש לרשום ולקדד את מספר המבחן המופיע בראש הדף בצד ימין (מספר בן 3 ספרות)
יש לרשום את מספר תעודת הזהות במקום המיועד בכתב יד ברור (כולל ספרת הביקורת)

בהצלחה!

דף טיוטה

דף טיוטה

דף טיוטה

<u>שאלה מספר 1:</u>

איזו מבין הטכניקות הבאות בשימוש בביצוע הרעלת DNS?

א. IP spoofing

ב. SYN flooding

ג. XSS

ד. SQL injection

<u>שאלה מספר 2:</u>

איזה מנגנון מאפשר לשרת להגיד לדפדפן אלו משאבים מותר לדפדפן לטעון/להריץ בהקשר של העמוד הנוכחי?

א. CSP

ב. HSTS

ג. CT

ד. NMAP

<u>שאלה מספר 3:</u>

איזה מהאלגוריתמים הבאים הינו אלגוריתם הצפנה (ופענוח) סימטרי?

א. DES

ב. RSA

ג. Diffie-Hellman

ד. SHA256

<u>שאלה מספר 4:</u>

איזו מהטענות הבאות <u>אינה</u> נכונה?

א. Metasploit הינו חומת אש אפליקטיבית.

ב. סריקת כתובות IP ופורטים פתוחים היא טכניקה המאפשרת השתלטות על מחשבים וגיוסם כבוטים.

ג. בעזרת סריקת כתובות IP אפשר לאסוף מידע על הקורבנות.

ד. חומת אש יכולה להיות מותקנת על מכשירי קצה (של לקוחות) או על שרתים או על רכיבי תקשורת מרכזיים.

<u>שאלה מספר 5:</u>

איזו מבין הטענות הבאות <u>אינה</u> נכונה?

א. ב syn-flood תוקף יעדיף כתובת IP מזוייפות כ source ובעיקר כאלו שלא יענו, כדי, בין השאר, לשפר את הסיכוי שישלח בחזרה RST על ה syn+ack

ב. IDS אינו מונע התקפות DNS poisoning

ג. תוקף בעל יכולות eavesdropping בין קורבן לשרת ה DNS שאליו פנה לא תמיד יצליח בהתקפת DNS poisoning

ד. על מנת לבצע ARP poisoning, התוקף אינו זקוק ליכולת MITM

<u>שאלה מספר 6:</u>

אילו מהטענות הבאות נכונה?

א. כיום, אחת השיטות הנפוצות לכרות ביטקוין היא באמצעות mining pools.

ב. אם אליס היא הבעלים כרגע של x ביטקוין כתוצאה מטרנזקציה y, היא תמיד תהיה הבעלים של המטבעות הללו, בתנאי שהיא לא בזבזה אותם.

ג. הבנק שעומד מאחורי ביטקוין דואג להזרים כסף למערכת לפי הצורך.

ד. אחד היתרונות של ביטקוין הוא שהוא מונע double spending לחלוטין.

<u>שאלה מספר 7:</u>

במנגנון החלפת המפתחות של דיפי הלמן מחליטים על שני מספרים פומביים g,n ואז אליס ובוב כל אחד בוחרים מספר סודי x, ובעזרת מספרים אלו מחשבים את y. הסעיפים הבאים מתארים תהליכים שמתרחשים או קשורים למנגנון.

בחרו את הסעיף <u>שאינו</u> נכון.

א. אליס ובוב (כל אחד בנפרד) מעלים את x בחזקת g (מודולו n) וכך מחשבים את y. הם שולחים את התוצאה אחד לשני (אליס לבוב ובוב לאליס).

ב. אליס מקבלת מבוב את y, ומעלה אותו בחזקת x (מודולו n). התוצאה המתקבלת היא המפתח המשותף.

ג. אליס ובוב (כל אחד בנפרד) מעלים את g בחזקת x (מודולו n) וכך מחשבים את y. הם שולחים את התוצאה אחד לשני (אליס לבוב ובוב לאליס).

ד. בוב מקבל מאליס את y, ומעלה אותו בחזקת x (מודולו n). תוקף מאזין אינו יכול לגלות את המפתח המשותף בגלל הקושי של בעיית הלוגריתם הדיסקרטי.

<u>שאלה מספר 8:</u>

נתון:

- **PKA הינו המפתח הפומבי של אליס ו SKA הוא המפתח הפרטי של אליס. בוב יודע את PKA.**
- **PKB הינו המפתח הפומבי של בוב ו SKB הוא המפתח הפרטי של בוב. אליס יודעת את PKB.**
- **Enc_x הינה פונק׳ הצפנה סימטרית עם המפתח x, ו Dec_x הינה פונק׳ הפענוח הסימטרית.**
- **E_x הינה פונק׳ הצפנה אסימטרית עם המפתח x, ו D_y הינה פונק׳ הפענוח האסימטרית עם המפתח y.**
- **H הינה פונק׳ hash.**
- **S_x הינה פונק׳ המבצעת חתימה דיגיטלית עם המפתח x, ו V_y הינה פונק׳ וידוא חתימה דיגיטלית עם המפתח y.**

אליס רוצה לשלוח הודעה M (קצרה) בצורה מאובטחת לבוב. הדרישה היא שהאופן בו ההודעה נשלחת יקיים סודיות, ויאפשר לבוב וידוא אותנטיות השולח ואמינות המידע. להלן הצעות שונות כיצד אליס רוצה לעשות זאת. ביחרו את ההצעה (היחידה) שמקיימת את הדרישה.

א. אליס שולחת לבוב:

$E_{PKB}(M),S_{SKA}(H(M))$

ב. אליס מייצרת מפתח סימטרי סודי s, ושולחת לבוב:

$E_{PKB}(s),Enc_s(M)$

ג. אליס מייצרת מפתח סימטרי סודי s, ושולחת לבוב:

$E_{PKA}(s),Enc_s(M)$

ד. אליס שולחת לבוב:

$E_{PKB}(M),S_{SKB}(H(M))$

<u>שאלה מספר 9:</u>

ssh הוא פרוטוקול סטנדרטי לתקשורת בין קליינט לסרבר מעל TCP. שרת ssh מאזין בפורט 22 עבור בקשות חיבור נכנסות. ברשת מסויימת יש שרת ssh וכמו כן שרת פרוקסי. שרת הפרוקסי מאזין בפורט 8080 (בלבד). רוצים לבנות טבלת חוקים ב firewall שתאפשר תנועה נכנסת ויוצאת של תעבורת ssh בלבד, כלומר, רוצים לאפשר קיום תקשורת ssh מתוך הרשת החוצה ומחוץ לרשת פנימה, אבל, שלא תתאפשר שום תעבורה אחרת. לכן הגדירו את הטבלה הבאה: (סדר החוקים מופיע בעמודה הימנית והוא גם סדר השורות בטבלה. כלומר, החוק הראשון הוא ראשון גם מבחינת סדר וכו')

חוק מספר	כיוון תעבורה	Src IP	Src port	Destination IP	Destination Port	פרוטוקול	פעולה
1	נכנסת	חיצונית	*	פנימית	22	TCP	Allow
2	יוצאת	פנימית	22	חיצונית	*	TCP	Allow
3	יוצאת	פנימית	*	חיצונית	22	TCP	Allow
4	נכנסת	חיצונית	22	פנימית	*	TCP	Allow
5	*	*	*	*	*	*	Drop

איזה טענה <u>אינה</u> נכונה?

א. תוקף שנמצא מחוץ לרשת אינו יכול להקים חיבור TCP מול שרת הפרוקסי שנמצא בתוך הרשת.

ב. ניתן היה לשפר את הבטיחות של הטבלה הנ"ל בעזרת הוספת עמודת flags, כלומר, לאפשר להגדיר חוק גם לפי דגלי TCP.

ג. החוקים כתובים בצורת whitelist.

ד. טבלת החוקים המתוארת בשאלה מאפשרת תנועה נכנסת ויוצאת של תעבורת ssh מהרשת החוצה ומחוץ לרשת פנימה.

<u>שאלה מספר 10:</u>

להלן מספר הצעות לשינויים לרשת ביטקוין, כאשר כל שינוי מלווה בטענה. עליכם לבחור את הסעיף עם הטענה <u>שאינה</u> נכונה.

א. כדי לחסוך בחשמל, מציעים שכריית בלוקים חדשים תתבצע רק כאשר יש כמות x של עסקאות חדשות שרוצות להיכנס לבלוקצ'יין. כלומר, אם כרגע ידוע על פחות מ x עסקאות חדשות, הminerים לא עושים כלום, והם יתחילו לחפש את הבלוק הבא רק כאשר יהיו x עסקאות חדשות או יותר. שינוי זה אינו מאפשר לתוקף לבצע double-spending.

ב. לאליס יש בעלות על 1 ביטקוין, ותוקף רשע ומרושע רוצה למנוע ממנה להעביר אותו למישהו אחר. התוקף שלנו הינו גאון, והצליח לפתח חומרה מיוחדת שמחשבת hash יותר מהר מכל miner קיים. למעשה, החומרה הזו כל כך חזקה, כך שכאשר הוא משתמש בה, היא מהווה 51% מהכוח החישובי של כל רשת הביטקוין. חומרה זו מאפשרת לו להשיג את מטרתו, אפילו אם אליס לעיתים תחשוב (זמנית) שהיא הצליחה להעביר את הביטקוין שלה למישהו אחר.

ג. אליס מחליטה לממש בעצמה תוכנה שתעקוב אחר הבלוקצ'יין ותוודא את תקינות הבלוקים והטרנזקציות בו. אליס חוששת שיגמר לה הזיכרון אם היא תשמור את כל הבלוקצ'יין. לכן, במקום לשמור את כל הבלוקצ'יין, היא שומרת את הבלוק האחרון שנוסף לבלוקצ'יין ואת רשימת כל העסקאות שעדיין לא בוזבזו. כאשר היא שומעת על בלוק חדש שנוסף, היא עושה את כל הבדיקות הרגילות שמחשבים שחברים בביטקוין עושים, כלומר, שהבלוק החדש כולל hash של הבלוק האחרון הנוכחי, שכל העסקאות בבלוק החדש תקינות (חתומות תקין, מבזבזות עסקאות שלא בוזבזו בלבד וכו'), הhash של הבלוק מכיל מספיק אפסים וכו'. אם הבלוק תקין, התוכנה שומרת אותו במקום הבלוק האחרון הנוכחי ששמור, ומעדכנת את רשימת העסקאות שלא בוזבזו בהתאם. המימוש הזה בעייתי ביחס למימוש הרגיל (שיש לו את כל הבלוקצ'יין), בגלל שאינו מתמודד טוב עם פיצולים (forks).

ד. נניח שלוקח 1 דקה עד שעסקה חדשה שפורסמה או בלוק חדש שנמצא מגיעים לכל המחשבים ברשת הביטקוין מהרגע שהם נוצרו (שהרי ביטקוין היא רשת peer to peer ולוקח זמן למידע להתפשט ברשת ממחשב אחד לשני). מציעים להוריד את משך הזמן הממוצע עד מציאת בלוק חדש מ10 דק׳ ל10 שניות. רעיון זה אינו טוב.

--- סוף המבחן ---